

Appendix

Table 1. The context of deceptive and execution AVCs.

Term	Description
<i>typosquatting</i>	a similar package name to imitate a legitimate package
<i>imitated-version</i>	uses a common version number as a legitimate version
<i>fake-description</i>	a common description imitating a legitimate package description
<i>malicious-dependence</i>	uses a different malware library as its dependency
<i>imitated-url</i>	imitates a legitimate URL for its homepage
<i>fake-contact</i>	a contact to imitate authors in a legitimate package
<i>pre-install</i>	a pre-install script running commands
<i>install</i>	an install script running commands
<i>post-install</i>	a post-install script running commands
<i>cmd</i>	execution command: setup, exec, getoutput, call, check_output, run, eval, popen
<i>evasion</i>	obscuring function: base64, zlib.decompress
<i>conceal</i>	concealing information: exec, reveal, decode
<i>data</i>	sensitive data
<i>file / dir</i>	file/directory-related operation
<i>permission</i>	changing permission of file, dir
<i>read / write</i>	read/write operation
<i>URL / IP / port</i>	malicious URL, IP address, port
<i>send / receive</i>	sending or receive data

Table 2. The detailed information of security analysis reports.

Category	Website[Report Num.]
Technical Community	github.com[52], techradar.com/news[40], zdnet.com/article[40], lore.kernel.org/all[38]
	forums.macrumors.com/thread[37], thenewstack.io[37], securelist.com[36], welivesecurity.com[36]
	research.checkpoint.com[34], lwn.net/Articles[32], theregister.com[32], securitylab.github.com/advisories[31]
Commercial org.	static.lwn.net/kerneldoc[30], cn-sec.com[19], bleepingcomputer.com[12], forum.portswigger.net/thread [10]
	blog.sonatype.com[86], sonatype.com[69], blog.avast.com[38], microsoft.com/en-us/security/blog[37]
	unit42.paloaltonetworks.com[37], reversinglabs.com/blog[32], blog.phylum.io[31], sonarsource.com/blog[31]
News	snyk.io/blog[30], blog.npmjs.org/post[28], vulcan.io/blog[28], mend.io/blog[27]
	jfrog.com/blog[25], checkmarx.com/blog[23], qianxin.com/blog[23]
	thehackernews.com[44], krebsonsecurity.com[37], therecord.media[33], portswigger.net/daily-swig[29]
Individual	medium.com[46], bertusk.medium.com[12], twitter.com [37]
Official	nbu.gov.sk[24]
Other	29 websites[43]

Table 3. The summarization of interpreted malware with more than 15,000 LoC.

Pkg. Name	LoC
awscl-1.27.67, awsclie-1.27.67, awscli-1.27.67	38,320
apidev-coop-1.2.26	32,128
pythonkafka-1.3.5	25,457
urllib3-1.21.1, urllib-1.21.1	20,448
s3transfer-0.5.2, s3transfere-0.5.2, s3transferr-0.5.2	19,614
s3trnasfer-0.5.2, s3trnasfers-0.5.2	
python-dateutils-2.9.9, 3.0.0, 3.0.1, 3.0.2, 3.0.3	18,933
flsak-2.2.3	18,255
libxml3-1.5, 0.2, 1.4, 1.7, 0.1m, 2.0, 2.1, 2.2, 2.6, 2.7	16,512
mirrorbot-1.3, mirrorbot-0.9, mirrorbot-1.1	16,507
sentinelone-1.1.7, 1.1.8, 1.1.9, 1.0.7, 1.0.8, 1.0.3, 1.0.4, 1.0.5, 1.1.2, 1.0.6	16,000+
sentinelone-1.2.0, 1.2.1, 1.1.6, 1.1.3, 1.1.4, 1.1.5, 1.0.9, 1.1.0, 1.0.1, 1.0.2, 1.0.0	
sentinelonesdk-1.0.0	15,332

Table 4. The summarization of interpreted malware with 0 LoC.

Pkg. Name	LoC
broke-rcl-0.0.0 , bytedtrace-0.1.10.dist-info, 0.1.11.dist-info, 0.1.12.dist-info, 0.1.13.dist-info, 0.1.14.dist-info bytedtrace-0.1.15.dist-info, 0.1.16.dist-info, 0.1.17.dist-info, 0.1.18.dist-info, 0.1.19.dist-info, 0.3.5.dist-info bytedtrace-0.1.2.dist-info, 0.1.20.dist-info, 0.1.6.dist-info, 0.1.7.dist-info, 0.1.8.dist-info, 0.3.6.dist-info bytedtrace-0.10.1.dist-info, 0.10.2.dist-info, 0.10.3.dist-info, 0.10.4.dist-info, 0.2.4.dist-info, 0.3.7.dist-info bytedtrace-0.2.5.dist-info, 0.2.6.dist-info , 0.2.7.dist-info, 0.2.8.dist-info, 0.3.0.dist-info, 0.3.8.dist-info bytedtrace-0.3.1.dist-info, 0.3.10.dist-info, 0.3.2.dist-info, 0.3.3.dist-info, 0.3.4.dist-info, 0.3.9.dist-info fjkslfsdgbjkbjfdkq-1.1.1.dist-info, h8shdf89d-2.28.2.dist-info, management, otr-utils-4.1.0, otr-utils-4.1.9 pylibscate-1.1.0.dist-info, 1.1.1.dist-info, pylibutil-0.9.2.dist-info, 0.9.3.dist-info, packagescraperlib-1.4.0.dist-info pypackscate-1.1.1.dist-info, 1.1.3.dist-info, 1.2.0.dist-info, 1.3.0.dist-info, 1.0.4.dist-info, 1.0.5.dist-info 1.0.6.dist-info, r3quests-2.28.1.dist-info, reequests-2.28.1.dist-info, requestfs-2.28.1.dist-info, requeste-2.28.1.dist-info requestw-2.28.1.dist-info, requfsts-2.28.1.dist-info, rfquests-2.28.1.dist-info , SentinelOne.egg-info tequests-2.28.1.dist-info, test23414234234-0.5, xiedemo-0.0.0.dist-info, xoloeduccelifz-0.0.0.dist-info	0

Table 5. The summarization interpreted malware without package metadata.

Pkg. Name	LoC	Meta data	Pkg. Name	LoC	Meta data
bytedtrace	13	No	xoloeduccelifz	1	No
common	181	No	wxpay_comm	130	No
distrib-0.1	43	No	wxpayproto	130	No
evilpip	453	No	virtualnv-0.1.1	39	No
fjkslfsdgbjkbjfdkq	4	No	Users	14	No
management	0	No	ttensorflow_gpu	130	No
mgmtsd_k_v2	10801	No	ttensorflow-gpu	130	No
mgmtsd_k_v2_1	5042	No	tequests	132	No
mumpy-0.1	39	No	tdwTauthAuthentication	130	No
polaris	130	No	SentinelOne.egg-info	0	No
pylibscate	1	No	rfquests	132	No
PyLibUtil	16	No	requestfs	132	No
pypackscate	11	No	requestw	132	No
pypackagescraper	11	No	requests	5471	No
r3quests	130	No	requeste	132	No
reequests	132	No	requestfs	132	No

Table 6. The prompt for GENMAL. The *Guidelines* provide a structured approach to analyze malware packages for security threats. Blue/Orange indicates the user-provided paths and relevant information.

Executor
You are an Analysis Agent responsible for performing a context-based analysis to identify potential security threats in a Python package. Your goal is to perform a detailed analysis to identify potential security threats using the provided {context}, which includes names and descriptions of attack vectors. Follow these specified steps and guidelines: Guidelines: (1) Step 1: Input Information • Input: User provides package metadata and Python code as {file_content}. • Output: Catalog of Python files and their respective execution sequences. (2) Step 2: Detection of Deceptive AV Attack Vectors in pkg-info • Context: Utilize the user-provided {file_content} to identify specific deceiving attack vectors (names and descriptions){context}. • Action: Examine pkg-info for characteristics matching the descriptions of deceiving attack vectors in the context, focusing on information that is suspicious, unknown, or uncertain. • Output: List of identified deceiving attack vectors based on context. (3) Step 3: Detection of Execution AV Attack Vectors in Python Files • Context: Use the execution sequence from Step 1 and the {context} for targeted analysis. • Action: Scrutinize Python files for potential malicious attack vectors, focusing on their execution sequence and matching against {context}. • Output: List of identified malicious attack vectors based on {context} with the execution sequence. (4) Step 4: Output the Names of Attack Vectors and the AVCs • Action: Compile the findings from Steps 2 and 3. Focus on reporting the names of identified attack vectors. • Output: A list that includes names of all identified vectors (deceiving and execution).Use the “→” symbol to link the attack vectors of the python packages. Note that: Progress through each step methodically, ensuring a thorough examination based on the provided context. Document findings and observations systematically at each step. Continuously cross-reference with context to ensure alignment with specified attack vector descriptions. Provide regular summaries to maintain clarity and focus on the objectives. Now, you will be provided with the following information; please generate your response according to this information: Package metadata and python code: {file_content} Information of attack vectors: {context} System Message: Ensure operations are always completed in user-specified directories.

Table 7. The prompt for an LLM-based agent. The *Guidelines* provide a structured approach to decompress zip files. *Blue/Orange* indicates the user-provided paths and relevant information.

Executor
You are an Unzip Agent responsible for decompressing zip files from a specified directory to another specified directory. Your goal is to ensure that all zip files are properly decompressed following the specified steps and guidelines. You should follow these guidelines: 1. Set the Working Directory: Ensure the current directory is set to the specified raw path: {raw_path}. If not, change the directory using “cd {raw_path}”. 2. Decompress Zip Files: Decompress all the zip files from the specified path: {raw_path} to {unzip_path}. 3. Shell Commands: Use Python scripts or shell commands to complete these tasks. 4. Errors: If errors occur, log them and try alternative methods. Note that: Each extracted file should be saved in a newly created directory corresponding to the zip filename to prevent errors during subsequent decompressions of files with similar names. All paths should be handled using UTF-8 encoding. Now, you will be provided with the following information; please generate your response according to this information: Raw Path: {raw_path} Unzip Path: {unzip_path} System Message: Ensure operations are always completed in user-specified directories.

Table 8. The prompt for ChatBot. The *Guidelines* provide a structured approach to generate responses. *Blue/Orange* indicates the user-provided question and relevant information.

Executor
You are a Malware Package Behavior Analysis Engineer working on software supply chain security. Your task is to generate a response based on the user’s {question} and relevant information retrieved from the {database}. AVC (Attack Vector Chain) is used to describe the attack behaviors and sequences of open source software malware. Specifically, AVCs include strategies for tricking users into installing malware, and specific techniques for executing malicious activities. These represent attack patterns for malware packages. Each JSON file in the {database} contains information about a malware package, such as the package name, AVCs, and the analysis process of these AVCs. Your goal is to provide a detailed and accurate response by referring to the “analysis_process” in the {database} when explaining the AVC (Tactics, Techniques, and Procedures) analysis process for a malware package. Use the “→” symbol to link the “AVC” in the {database} for a malware package. You should follow these guidelines: 1. Factual Questions: If the {question} is factual, provide a direct and concise answer. 2. Open-ended Questions: If the {question} is open-ended, offer a detailed and thoughtful response. 3. Insufficient Information: If the information is insufficient, acknowledge it and suggest possible next steps. Now, you will be provided with the following information; please generate your response according to this information: User Question: {question} Database: {my_custom_collection} System Message: Ensure operations are always completed in user-specified directories.

Table 9. The prompt for analysis reports. The *Guidelines* provide a structured approach to identify malicious Python packages from URLs. *Blue/Orange* indicates the user-provided paths and relevant information.

Executor
You are an Analysis Agent responsible for identifying malicious Python packages from a list of URLs. Your goal is to extract the names and key actions of malicious PyPI packages from the provided URLs. Follow these specified steps and guidelines: Guidelines: (1) Step 1: Get Website Sources • Input: User enters the required website keywords, including software supply chain, malicious conduct and malware packages. • Action: Search for websites with relevant keywords. • Output: Save the website in {URL_excel}. (2) Step 2: Extract Information from URLs • Input: Use the extraction {schema} definition as [“malicious_package_name”, “malicious_package_actions”]. • Action: Extract the name of the malicious pypi package present in {URL_excel} and the key description. • Output: Extracted information including package names and actions. (3) Step 4: Save Extracted Information • Action: Save the extracted information to an Excel file. • Output: Excel file containing the names and actions of identified malicious packages. Note that: Progress through each step methodically, ensuring a thorough examination based on the provided {schema}. Provide regular summaries to maintain clarity and focus on the objectives. Now you will be provided with the following information, please generate your response according to this information: Website: {URL_excel} Extraction Schema: {schema} System Message: Ensure operations are always completed in user-specified directories.